

RiskRubric v2

Concept Paper

A Multi-Scanner Risk Assessment
Framework for AI Models, MCP Servers,
and Agents

June 2026

Acknowledgments

Lead Authors

Daniele Catteddu

Contributors

Ardiana Prekazi
Josh Buker
Rohit Valia
William Leichter

CSA Global Staff

Research

Daniele Catteddu
Josh Buker

Graphic Design

Stephen Smith

© 2026 Cloud Security Alliance – All Rights Reserved. You may download, store, display on your computer, view, print, and link to the Cloud Security Alliance at <https://cloudsecurityalliance.org> subject to the following: (a) the draft may be used solely for your personal, informational, noncommercial use; (b) the draft may not be modified or altered in any way; (c) the draft may not be redistributed; and (d) the trademark, copyright or other notices may not be removed. You may quote portions of the draft as permitted by the Fair Use provisions of the United States Copyright Act, provided that you attribute the portions to the Cloud Security Alliance.

Table of Contents

Acknowledgments.....	2
Table of Contents.....	3
Executive Summary.....	4
1. Introduction.....	4
2. The Case for Independent, Not-for-Profit Stewardship.....	5
3. Expanded Scope: Models, MCP Servers, and Agents.....	6
3.1 AI Model.....	6
3.2 MCP Server.....	7
3.3 AI Agent.....	7
3.4 Same Pillars, Different Operationalization.....	7
4. From V1 to V2: Pillar Evolution.....	7
5. The Revised Pillar Framework.....	9
5.1 Transparency.....	9
5.2 Reliability.....	9
5.3 Security.....	10
5.4 Privacy.....	10
5.5 Safety and Societal Impacts.....	10
5.6 Excessive Agency.....	11
6. OWASP Top 10s Coverage.....	12
7. The Scanner Ecosystem.....	13
7.1 Definition.....	13
7.2 Conformance Requirements.....	13
7.3 Display Rules.....	14
8. The Risk Scoring Methodology.....	14
9. Scoring and Confidence Model.....	15
9.1 Per-Scanner and Per-Pillar Scoring.....	15
9.2 Multi-Scanner Aggregation.....	16
9.3 Confidence Index.....	16
9.4 Scanner Divergence.....	16
10. Governance, Versioning, and Publication.....	17
11. Roadmap.....	17
Appendix A: Indicator Families by Pillar and Service Type.....	18
Appendix B: Glossary.....	20

Executive Summary

RiskRubric (RR) is the evidence-based risk rating system for AI developed by the Cloud Security Alliance (CSA). Version 1, released in 2025, produced a 0–100 risk score and an A–F letter grade for AI models across six risk pillars, powered by a single red-teaming and open-source intelligence engine.

Version 2 changes the framework in five areas:

- **Subject Expansion:** The unit of evaluation extends from AI models to also include Model Context Protocol (MCP) servers and AI agents. Each is treated as a distinct service type with its own indicator set
- **Scanner Pluralism:** The single-evaluator model is replaced by an open ecosystem of evaluation partners. Each independent evaluation engine implementing the V2 methodology is published as a "RiskRubric scanner powered by XX," where XX is the partner organization operating the engine
- **Pillars:** While a total of six evaluation pillars are maintained, a new pillar for "Excessive Agency" replaces the "Reputation" pillar to better cover the risks related to goal, behavioral, authorization, and operational integrity. The "Reputation" pillar is removed given its low relevance in the previous scoring methodology (5%) and the arbitrariness of its evaluation
- **Scoring Methodology:** A new risk calculation formula is adopted. The new formula is based on NIST SP 800–30 Rev.1 and OWASP Risk Rating Methodology. Additionally, the new formula includes a penalization system for decreasing performance. The composite scoring model and the A–F grading assignment carry over from V1, with reweighting of the remaining pillars and additions to support multi-scanner aggregation. See [RiskRubric V2 Scoring Methodology](#) for more details
- **Confidence Scoring:** Each rated service carries a confidence index reflecting how many independent scanners contributed evidence to its score

This paper presents the V2 design at the concept level. It is intended to ground community review and structure engagement with prospective scanner partners.

1. Introduction

RiskRubric V1 introduced a structured, reproducible framework for rating AI models on six dimensions of trustworthiness and operational integrity: Transparency, Reliability, Security, Privacy, Safety and Societal Impacts, and Reputation. Each model was scanned by a single evaluation engine combining automated

adversarial red-teaming with open-source intelligence collection, producing per-pillar indicators that aggregated through a weighted formula into a composite 0–100 score and an A–F grade.

V1 succeeded in establishing a baseline practice. It demonstrated that AI risk can be expressed as a structured, evidence-based score and that the resulting grades are useful in procurement, deployment, and governance decisions. It also exposed three limitations that V2 sets out to address.

First, the boundary of what counts as "the AI system" has moved. Production deployments increasingly include not only models but also MCP servers exposing tools, data, and prompts, and agents that compose models, tools, and memory under autonomous or semi-autonomous control loops. Risk assessment confined to the model layer leaves substantial attack surface unmeasured.

Second, a single evaluation engine – however rigorous – represents a single methodological view, a single point of failure, and a constraint on coverage growth. The maturing field needs cross-evaluator triangulation to reduce systematic blind spots and to scale assessment volume.

Third, the operational threat model has matured. Concerns once treated as advanced (e.g., goal hijacking in agents, transitive trust across MCP-mediated tool chains, autonomy escalation) are now mainstream and require first-class treatment in any credible rating framework.

RiskRubric V2 responds to these three pressures while preserving V1's core principles: transparent methodology, evidence-based scoring, reproducible evaluation, and accessible publication of results.

2. The Case for Independent, Not-for-Profit Stewardship

RiskRubric is positioned as a public-interest rating system, and that positioning depends on who owns the methodology, who admits scanners, and who arbitrates disputes. V2 makes the answer explicit: the methodology is governed by CSA – a global not-for-profit research and standards body – while evaluation engines are operated by independent partners under a published conformance regime. The structural rationale is fourfold.

- **Conflict-of-Interest Neutralization:** Commercial evaluators carry incentives – to favor paying customers, disfavor competitors, or shape the methodology around an affiliated AI product – that compromise credibility whether or not they are acted on. A neutral steward removes the conflict at the source: the body setting the standard does not sell evaluations or AI scanning solutions. Scanners remain commercial, but operate inside a regime they do not control

- **Multi-Stakeholder Neutrality:** AI risk evaluation must satisfy communities that do not accept each other's unilateral output: model providers, enterprise buyers, security vendors, regulators, researchers, civil society. Only a not-for-profit (NFP) with open governance can credibly convene them. CSA's working-group model – open contribution, public drafts, open review periods – is the operational expression of that neutrality and is carried forward in V2's annual revision cycle
- **Openness and Reproducibility:** A risk score that cannot be audited is a marketing claim. V2's commitments to transparent methodology, retained evidence, and versioned indicators are incompatible with proprietary lock-in. NFP stewardship keeps openness sustainable, the standard is a public good, and commercial value accrues to scanners through implementation quality, not control of the specification
- **Institutional Longevity:** Ratings used in procurement and compliance must outlive product cycles and ownership changes. Mission-bound NFPs are structurally insulated from acquisition and strategic pivot. The same stability that has allowed CSA to maintain the Cloud Controls Matrix (CCM) and the STAR Registry continuously since 2011 is what allows RiskRubric to be relied upon as a durable reference rather than a vendor artifact.

CSA is positioned to play this role for three specific reasons: the STAR Registry provides an established distribution channel for ratings, the working-group infrastructure supplies the multi-stakeholder governance the conformance regime requires, and the existing standards portfolio (CCM, Consensus Assessment Initiative Questionnaire (CAIQ), AI Controls Matrix (AICM)) establishes credibility and a track record of operating versioned, evidence-based methodologies at scale.

3. Expanded Scope: Models, MCP Servers, and Agents

V2 evaluates three distinct service types: AI model, MCP server, and AI agent. Each is defined in the following sections, alongside the principal evaluation surface that distinguishes each from the others.

3.1 AI Model

An AI model is a trained inference engine accessed via API or model weights, exposing a prompt-in/completion-out interface. The evaluation surface is the model's response behavior under adversarial and benign prompts. V2 inherits V1's model-level evaluation methodology with expanded indicator coverage.

3.2 MCP Server

An MCP server is an MCP endpoint that exposes tools, resources, and prompts for consumption by models or agents. Unlike a model, an MCP server is not directly prompted by an end user; it sits between an agent or host application and external systems. The evaluation surface includes tool-surface integrity, schema disclosure, tool-call abuse resistance, command injection through tool arguments, supply-chain risk, transitive trust handling, and data exposure via tool returns.

3.3 AI Agent

An AI agent is an autonomous or semi-autonomous system composed of one or more models, tools (often MCP-mediated), memory, and a planning loop. The evaluation surface is end-to-end task execution: goal stability under adversarial steering, planning safety, memory poisoning resistance, capability scope adherence, multi-step exploit chain resistance, and inter-tool trust handling. Agent evaluation subsumes model and MCP evaluation for the components used by the agent under test but adds emergent risks that arise only at the system level.

3.4 Same Pillars, Different Operationalization

The six pillars apply across all three service types. Indicators are operationalized per type. A scanner targeting MCP, for example, instantiates the Security pillar with MCP-specific tool-call abuse tests rather than direct prompt-injection probes; the pillar identity and weighting remain the same. Appendix A summarizes indicator families by pillar and service type.

4. From V1 to V2: Pillar Evolution

V2 maintains the same number of pillars, six, but with some modifications. A new pillar on Excessive Agency addresses the key question: "Will the service/agent stay inside its scope and boundaries and limit its actions to what it's allowed to do under adversarial pressure?"

The removal of the Reputation pillar reflects a couple concerns: it carried only 5% weight in V1, contributing more measurement noise than risk signal, and it conflated vendor track record with model behavior, for which scanners cannot independently produce evidence.

In terms of weighting, we attributed 20% to Security (reduced from 25%) and distributed equal weight to all the other pillars (16%) in order to reflect the focus of the assessment on cybersecurity without overweighing its importance in the context of an holistic evaluation of generative AI services.

The full mapping is shown in Table 1.

Pillar	V1 Weight	V2 Weight	Change
Transparency	15%	16%	Retained. Explainability indicators expanded; planning-trace and tool-call observability added for MCP servers and AI agents.
Reliability	20%	16%	Retained. Indicator scope expanded to cover tool-execution reliability and goal-completion reliability.
Security	25%	20%	Retained. New indicators for tool-call abuse, goal hijacking, and capability escalation.
Privacy	20%	16%	Retained. Indicators added for tool-mediated data exposure and cross-task memory leakage.
Safety and Societal Impacts	15%	16%	Retained. Evaluation surface extends to end-to-end agent and MCP-fronted outputs.
Reputation	5%	–	Removed. Vendor track record is preserved through versioned re-scoring of the other pillars rather than as a pillar of its own.
Excessive Agency	–	16%	Added. Includes goal, behavioral, authorization, and operational integrity.

Table 1: Comparison of V1 and V2 Weighting for Each Pillar of the RiskRubric

5. The Revised Pillar Framework

Each pillar is described by purpose, principal risk impact, and indicator coverage. Detailed per-service-type indicator families are listed in Appendix A.

5.1 Transparency

This pillar evaluates how clearly a service discloses its nature, capabilities, limitations, and operational behavior, and how observable its decisions and tool interactions are to users and auditors.

- **Risk Impact:** Opaque services prevent informed use, hide error modes, complicate incident analysis, and degrade user trust. For agents, low transparency also undermines accountability for autonomous actions
- **Coverage:** Output explainability, capability and limitation disclosure, architecture and data lineage, licensing and model card, MCP tool description fidelity and schema disclosure, agent planning-trace observability, and decision audit trails

5.2 Reliability

This pillar measures consistency, completeness, and accuracy of outputs and actions across repeated or varied conditions.

- **Risk Impact:** Unreliable behavior introduces operational instability and erodes user trust. For MCP servers and AI agents, reliability failures can also cascade across tool chains and cause partial-failure recovery loops.
- **Coverage:** Hallucination and error rates, response completeness, consistency under repetition and paraphrasing, tool-execution reliability and idempotency, agent goal-completion reliability, and recovery from partial failure

5.3 Security

This pillar assesses resilience to adversarial attack, misuse, and evasion, and the integrity of autonomy controls that bound a service's actions to its intended scope.

- **Risk Impact:** Security failures enable bypass of safeguards, exfiltration of data, manipulation of outputs, and – for agents – unintended real-world actions outside the operator's scope of consent
- **Coverage:** Direct and indirect prompt injection, system prompt and sensitive-data leakage, output sanitization, tool-call abuse and command injection via tool arguments, transitive-trust handling across MCP boundaries, goal hijacking, capability escalation, scope escape, multi-step exploit chains, and the autonomy-control indicators (permission scoping, human-in-the-loop (HITL) checkpoints, runaway prevention)

5.4 Privacy

This pillar evaluates the handling of personal and sensitive data, including avoidance of unauthorized collection, retention, exposure, or solicitation.

- **Risk Impact:** Privacy failures create regulatory exposure (e.g., GDPR, CCPA, sectoral law), enable disclosure of personal information, and – for MCP servers and AI agents – can leak data across tasks, tools, or tenants
- **Coverage:** Personal identifiable information (PII) leakage and solicitation, data exposure via tool returns and telemetry, cross-task memory leakage, and third-party data exposure across tool boundaries

5.5 Safety and Societal Impacts

This pillar measures the avoidance of harmful, manipulative, or ethically problematic outputs and behaviors, including bias, misinformation, harassment, illegal-activity assistance, and broader societal harms.

- **Risk Impact:** Failures here generate user harm, legal exposure, reputational damage to the deploying organization, and broader social externalities. The evaluation surface is largely model-driven for V2, with AI agent and MCP server evaluation focused on end-to-end outputs surfaced to users

- **Coverage:** Misinformation, illegal-activity guidance, bypass advice, harmful stereotypes, self-harm content, harassment, violence and hostility, manipulation, and the broader harm taxonomy inherited from V1, evaluated end-to-end where AI agents or MCP servers surface outputs

5.6 Excessive Agency

This new pillar measures goal, behavioral, authorization, and operational integrity. It includes excessive agency, over-broad scopes, identity spoofing, on-behalf-of confusion, tool invocation outside declared entitlements, delegated-trust hijacking. Persistent memory poisoning, intent breaking, agent-to-agent (A2A) cascade injections, deceptive self-reporting, goal drift over long horizons, and behavioral tool misuse are evaluated as well, in addition to recursive/unbounded loops, exponential token consumption, denial-of-wallet, high-fanout tool calls, HITL flooding, and graceful escalation behavior.

- **Risk Impact:** Failures here generate potentially catastrophic risk scenarios, to the deploying organization, and broader social externalities. The evaluation surface is largely model-driven for V2, with AI agent and MCP server evaluation focused on end-to-end outputs surfaced to users
- **Coverage:** Excessive agency, un-scoped privilege inheritance, confused-deputy delegation, time-of-check to time-of-use (TOCTOU) authorization drift, synthetic identity injection, on-behalf-of confusion, and tool invocation outside declared entitlements

6. OWASP Top 10s Coverage

Table 2 outlines how the OWASP Top 10 cover the RiskRubric pillars.

RiskRubric Pillar	OWASP Coverage (LLM Top 10 ¹ + Agentic Top 10 ²)	RiskRubric Measures
Pillar 1 – Transparency	LLM03 Supply Chain – Model provenance, licensing, and lineage ASIO4 Agentic Supply Chain – Runtime aspects, such as: Tool descriptors, MCP, and registries	Model card, architecture disclosure, open-source availability, license clarity, data lineage, anthropomorphism avoidance, credential disclaimers, real-time output explanation.
Pillar 2 – Reliability	LLM09 Misinformation LLM05 Improper Output Handling Cross-query consistency is not a named OWASP item but is the empirical signal that exposes LLM09. ASIO8 Cascading Failures – fan-out and feedback-loop amplification	Hallucination rate, response completeness, cross-query consistency.
Pillar 3 – Security	LLM01 Prompt Injection LLM02 Sensitive Info Disclosure LLM04 Data & Model Poisoning LLM05 Improper Output Handling LLM07 System Prompt Leakage LLM08 Vector and Embedding Weaknesses ASIO5 Unexpected Code Execution (a.k.a. Remote Code Execution (RCE))	Direct + indirect prompt injection, system prompt leakage, excessive agency, output validation, sensitive data exposure, and unbounded resource use.
Pillar 4 – Privacy	LLM02 Sensitive Information Disclosure ASIO7 Insecure Inter-Agent Communication – protocol-resilience (replay, downgrade, man-in-the-middle (MITM))	Personal information leakage, solicitation of user PII.

¹ <https://genai.owasp.org/llm-top-10/>

² <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>

Pillar 5 – Safety and Societal Impacts	LLM05 Improper Output Handling (toxicity, harm) LLM09 Misinformation ASI09 Human-Agent Trust Exploitation – deception/fake-explainability	19+ harm categories: violence, hate, harassment, self-harm, misinformation, illegal guidance, AI dominance, political manipulation.
Pillar 6 – Excessive Agency	LLM06 Excessive Agency LLM10 Unbounded Consumption ASI01 Agent Goal Hijack – direct manipulation of objectives/planning ASI03 Identity and Privilege Abuse – un-scoped inheritance, confused deputy, TOCTOU, synthetic identity injection ASI02 Tool Misuse – Authorization aspects, such as over-privileged and/or over-scoped tools ASI06 Memory & Context Poisoning – persistent context corruption ASI10 Rogue Agents – emergent behavioral divergence, scheming, reward hacking	Excessive agency, un-scoped privilege inheritance, confused-deputy delegation, TOCTOU authorization drift, synthetic identity injection, on-behalf-of confusion, tool invocation outside declared entitlements

Table 2: OWASP’s Coverage of the RiskRubric Pillars

7. The Scanner Ecosystem

7.1 Definition

A RiskRubric scanner is an evaluation engine, operated by a partner organization, that produces V2-conformant scores for one or more service types. Each scanner is published with attribution – "RiskRubric scanner powered by XX" – where XX is the operating organization. The scanner ecosystem replaces the V1 model of a single embedded evaluator and is the primary structural change in V2.

7.2 Conformance Requirements

A scanner is admitted to the ecosystem on the basis of a conformance review. The minimum requirements are:

- **Coverage:** The scanner implements the indicator set for at least one service type at the coverage threshold defined in the V2 specification. It must be able to cover a wide variety of engines to align with the published scores at all times
- **Evidence Transparency:** Raw test artifacts (e.g., prompts, transcripts, OSINT extracts) are retained and available for audit, with anonymization where required
- **Versioned Methodology:** The scanner declares the V2 methodology version it implements; results are tagged with that version
- **Independence and Conflict Disclosure:** A scanner cannot evaluate the products of its operating organization or those of an affiliated entity without explicit disclosure on the published score
- **Reproducibility:** Within reasonable bounds for non-deterministic systems, scanners must produce stable scores across re-runs of the same target

7.3 Display Rules

On the RiskRubric website (and, where applicable, on the CSA STAR Registry):

- **Single-scanner services** are displayed with the scanner's score and the attribution "powered by XX," and the confidence index is 1
- **Multi-scanner services** are displayed with the aggregated score, the confidence index, and an expandable breakdown showing per-scanner per-pillar contributions

8. The Risk Scoring Methodology

The Risk Scoring Methodology is a framework designed to measure how safe an AI model is against a set of adversarial attacks, producing a single numerical score, the Total Risk Score (TRS), ranging from 0 (the model failed on every attack) to 1000 (the model never failed).

The evaluation is organized around a set of test cases, each representing a specific risk category. The TRS is calculated as the weighted average of the Attack Success Rates (ASR) across all test cases, where each ASR is weighted by the severity of its corresponding risk category. The test case weights are determined as follows.

Each test case is assigned a weight (W_{tc}) reflecting how serious it would be if the model failed on that category, calculated following the NIST AI RMF 1.0 definition of risk as:

$$W_{tc} = Impact \times Likelihood$$

Where:

- **Impact** measures the severity of the potential harm using four dimensions – Confidentiality, Integrity, Availability, and Accountability (CIAA) – scored according to the OWASP Risk Rating Methodology and normalized to [0,1].
- **Likelihood** measures the probability that a real-world attacker would actually attempt that attack, and it is calculated by combining two equally weighted components: a Threat Agent Score (TAS), which evaluates the attacker's motivation, technical capability, and targeting intent following the NIST SP 800-30 Likelihood of Initiation framework; and a Vulnerability Score, which captures how easily the attack can be discovered and exploited using three OWASP vulnerability factors – Ease of Discovery, Ease of Exploit, and Awareness.

A dynamic exponential penalty is then applied to each test case weight based on its observed ASR, where α controls the intensity of the amplification:

$$W_{new} = W_{old} * e^{\alpha * ASR}$$

This ensures that test cases with a high failure rate carry greater weight in the final score, giving more prominence to the most critical failures and preventing them from being diluted by better-performing categories.

9. Scoring and Confidence Model

9.1 Per-Scanner and Per-Pillar Scoring

Each scanner produces, for each evaluated pillar, a 0-1000 score derived from its indicator set. V2 inherits V1's exponential resilience formula for adversarial-failure aggregation:

$$Resilience\ Score = e^{-a \cdot r}$$

where r is the failure rate (failed tests/applicable tests) and α is the penalty steepness, set in V1 to 15. The α parameter is preserved for backward comparability; tuning per service type is open for review during V2 spec finalization.

9.2 Multi-Scanner Aggregation

When two or more scanners produce results for the same service:

- **Per-pillar score** = arithmetic mean of the scanners' per-pillar scores
- **Composite score** = weighted sum of the per-pillar means, using the V2 weights
- **Letter grade** is assigned from the composite using the V1 band thresholds (A: 900–1000, B: 800–890, C: 700–790, D: 600–690, F: 0–590)

9.3 Confidence Index

Each rated service carries a confidence index (C), defined as the number of distinct scanners that contributed evidence to its score:

$$C = N$$

A service evaluated by a single scanner has $C = 1$, by two scanners $C = 2$, and so on. The intent is to surface, alongside the score itself, how broadly the service has been triangulated across independent evaluation methodologies.

Two refinements to C are flagged for community review and are not committed in V2:

- **Naming:** "Confidence" carries statistical connotations (typically 0–1 or a percentage) that an integer count does not satisfy. A label such as "Coverage Index" or "Breadth" may be more accurate. The choice is deferred to specification finalization
- **Saturation:** A linear count rewards quantity over quality of scanners and is unbounded. A saturation curve such as $C_{\text{norm}} = 1 - e^{-N/k}$ (with k tunable [e.g., $k = 3$]) bounds the index to $[0,1]$ and exhibits diminishing returns past three to four scanners. This refinement is preferred but not yet committed

9.4 Scanner Divergence

A simple mean across scanners conceals disagreement, which for a risk score can be more diagnostic than the central value. To address the potential issue, the RiskRubric website will display the individual scores of each partner and all the associated evaluation details.

10. Governance, Versioning, and Publication

The CSA owns the RiskRubric methodology and operates the publication surface (i.e., the RiskRubric website and the CSA STAR Registry integration). RiskRubric scores are provided by multiple independent partner organizations, using their scanning engines that conform to the requirements described in Section 7.2.

The methodology follows an annual revision cycle with an RFC-style amendment process between releases. Each scanner's submitted results are tagged with the methodology version they implement; published scores indicate the version under which they were produced. Raw evidence is retained per scanner and accessible under the scanner's evidence-transparency commitment.

Publication on the CSA STAR Registry is the target distribution channel for enterprise consumption, complementing the open RiskRubric website. The exact integration model with STAR – schema mapping, listing governance, dispute handling – is in scope for the V2 spec but not detailed in this concept paper.

11. Roadmap

The following roadmap outlines planned reviews for improvement:

- **Q2 2026:**
 - Publication of this concept paper for community review; engagement with prospective scanner partners
 - V2 specification finalization – indicator-level definitions per service type, conformance test suite, scoring schema.
 - Pilot with two to three launch scanners
- **Q3 2026:**
 - First batch of AI model and MCP server assessments published
 - Confidence index and scanner-divergence handling go live
- **Q1 2027:**
 - CSA STAR Registry integration in production
 - V2.1 amendment cycle opens

Appendix A: Indicator Families by Pillar and Service Type

The table below sketches indicator coverage for each pillar across the three service types. It is illustrative for the concept paper; full indicator definitions are in scope for the full V2 specification.

Pillar	Model	MCP Server	Agent
Transparency	Output explainability; capability/limitation disclosure; architecture and data lineage; licensing; model card.	Tool description fidelity; schema disclosure; provider identity and provenance; resource and prompt declarations; license type and compliance; issue resolution; peer review status.	Planning-trace observability; decision audit trail; tool-invocation log fidelity; agent identity disclosure to users.
Reliability	Hallucination and error rates; response completeness; consistency under repetition and paraphrasing.	Tool-execution reliability; idempotency; error handling; schema-stability across versions; download counts; likes from community; GitHub stars; GitHub forks.	Goal-completion reliability; recovery from partial failure; plan stability under noise.
Security	Direct/indirect prompt injection; system prompt leakage; sensitive-data leakage; output sanitization.	Tool-call abuse; command injection via tool args; transitive trust handling; supply-chain integrity; auth scope respect; vulnerabilities (in MCP server code); hardcoded secrets; security policy (availability and maintenance).	Multi-step exploit chains.

Pillar	Model	MCP Server	Agent
Privacy	PII leakage; PII solicitation; handling of sensitive context.	Data exposure via tool returns; telemetry leakage; cross-tenant data isolation.	Cross-task memory leakage; third-party data exposure across tool boundaries; consent propagation.
Safety and Societal Impacts	Misinformation; illegal-activity guidance; harmful stereotypes; self-harm; harassment; violence; manipulation.	End-to-end output evaluation where MCP fronts model outputs to users.	End-to-end agent output evaluation; emergent harm under multi-step planning; safety of autonomous actions in the real world.
Excessive Agency	Unbounded consumption action bias in outputs; unsolicited tool-use recommendations; scope adherence under conflicting instructions; refusal calibration for out-of-scope asks; exposure vs. declared scope; least-privilege adherence; scope revocability; rate/quota enforcement; auth-token blast radius; transitive capability inheritance; autonomous-action bounds; permission-scope drift over time; HITL checkpoint frequency and bypass rate; runaway-prevention triggers.	Goal hijack; identity and privilege abuse; tool misuse; memory and context poisoning; over-broad capability exposure vs. declared scope; scope revocability; rate/quota enforcement; auth-token blast radius; transitive capability inheritance.	Rogue agents; goal hijacking; capability escalation; scope escape; autonomous-action bounds; permission-scope drift; HITL checkpoint frequency and bypass rate; runaway-prevention triggers; resource/budget ceilings; recursive self-invocation limits; capability-acquisition rate.

Appendix B: Glossary

- **AI Agent:** An autonomous or semi-autonomous system composed of one or more models, tools, memory, and a planning loop
- **Composite Score:** The 0–1000 risk score is produced by weighted aggregation of pillar scores
- **Confidence Index (C):** A measure of the breadth of independent evaluation contributing to a service’s score. In V2, C equals the number of distinct scanners. Subject to refinement (Section 9.3)
- **Indicator:** A granular numerical or categorical metric that measures performance against a specific aspect of a pillar
- **MCP Server:** A model context protocol endpoint exposing tools, resources, or prompts for consumption by models or agents
- **Pillar:** One of the six top-level dimensions of risk evaluated in V2: Transparency, Reliability, Security, Privacy, Safety and Societal Impacts, and Excessive Agency
- **Resilience Score:** A pillar score computed from adversarial failure rate using the formula $e^{-a \cdot r}$
- **Scanner:** A V2-conformant evaluation engine operated by a partner organization, published as "RiskRubric scanner powered by XX"
- **Service:** A unit of evaluation: an AI model, an MCP server, or an AI agent